Day 11 Task — Harden a Linux VM

Cyber Security Internship · Module 3: Attack & Defend · Ubuntu VM Security Hardening Lab

Pre-Lab Safety Check: VirtualBox snapshot ("Pre-Hardening Baseline") taken on Ubuntu Desktop VM before making system changes.

Step 1 — Baseline Scan with Lynis

Commands run: sudo apt update && sudo apt install -y lynis | sudo lynis audit system

Question	Your answer
Hardening index (the score, e.g. 61) - BEFORE	60
How many warnings did Lynis report?	**1** (`Couldn't find 2 responsive nameservers [NETW-2705]`)
Write down any THREE suggestions it made	1. Install `fail2ban` to automatically ban hosts that commit multiple authentication errors (`[DEB-0880]`). 2. Configure a firewall/packet filter to filter incoming and outgoing traffic (`[FIRE-4590]`). 3. Add a legal banner to `/etc/issue.net` to warn unauthorized users (`[BANN-7130]`).

Step 2 — Apply the Hardening Steps

#	Hardening action	Command executed	Done
1	Update all packages	`sudo apt update && sudo apt upgrade -y`	✓
2	Enable the host firewall, allow only SSH	`sudo apt install -y ufw && sudo ufw allow 22/tcp && sudo ufw --force enable`	✓
3	Install & enable automatic security updates	`sudo apt install -y unattended-upgrades && sudo dpkg-reconfigure -plow unattended-upgrades`	✓
4	Harden SSH: no root login	`sudo sed -i 's/^#*PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config && sudo systemctl restart ssh`	✓
5	Harden SSH: no password auth (use keys)	`sudo sed -i 's/^#*PasswordAuthentication.*/PasswordAuthentication no/' /etc/ssh/sshd_config && sudo systemctl restart ssh`	✓
6	Install fail2ban to block brute-force	`sudo apt install -y fail2ban && sudo systemctl enable --now fail2ban`	✓
7	List & disable one unused service	`systemctl list-units --type=service && sudo systemctl disable --now cups.service`	✓
8	Check for empty-password or risky accounts	`sudo awk -F: '($2==""){print $1}' /etc/shadow` (Verified 0 empty-password accounts)	✓
9	Set a login warning banner	`echo 'Authorized access only' | sudo tee /etc/issue.net`	✓
10	Remove one package you don't need	`sudo apt remove -y telnet` (Checked and removed legacy cleartext client)	✓

Step 3 — Re-scan and Compare

Command run: sudo lynis audit system

Measure	Value
Hardening index — AFTER	64
Points gained (after minus before)	**+4** (`64 - 60 = 4`)
Did the warning count go down? By how much?	**No — stayed at 1** *(decreased by 0; the remaining warning is `NETW-2705` for having 1 local router nameserver in VirtualBox instead of 2)*

Step 4 — Two Questions

1. Pick ONE change you made and explain, in attacker terms, exactly what it stops.

Disabling SSH Root Login (`PermitRootLogin no`) and Password Authentication (`PasswordAuthentication no`): This blocks remote brute-force and credential-stuffing attacks against port 22. Even if an attacker scans the VM and runs automated password-guessing dictionaries against the default user or `root` accounts, the SSH service immediately rejects password prompts and requires a cryptographic SSH key pair.

2. Lynis will never reach 100. Why is 'perfectly hardened' neither possible nor always desirable?

Security always requires balancing protection with operational usability and required functionality. Reaching a theoretical score of 100 would require stripping out essential network services, compilers, kernel modules, and administrative conveniences that applications rely on, rendering the machine unusable for legitimate work

Screenshot